

PASTA WORKSHEET

Stages	Sneaker company
I. Define business and security objectives	• Enable a secure and seamless platform for users to buy and sell sneakers, including account registration, authentication, and transaction processing. • Protect sensitive user data, including personal information and payment details, to maintain trust and comply with legal and regulatory requirements. • Ensure a reliable and user-friendly experience that supports communication between buyers and sellers while maintaining system integrity and availability.
II. Define the technical scope	List of technologies used by the application: • <i>API</i> • <i>PKI</i> • <i>AES</i> • <i>SHA-256</i> • <i>SQL</i> APIs and SQL databases are prioritized because they handle data exchange and storage, making them primary targets for attacks such as injection and unauthorized access. Securing these components is critical to protecting sensitive user and transaction data, while encryption and hashing mechanisms support overall data protection.
III. Decompose application	Data flow diagram
IV. Threat analysis	SQL Injection Vulnerability The application may be vulnerable to SQL injection if user inputs (e.g., search queries or login fields) are not properly validated or parameterized, allowing attackers to manipulate database queries and access or modify sensitive data. Broken Authentication & Authorization in API Weak authentication or improper authorization controls in APIs could allow attackers to access other users' accounts, view

	sensitive data, or perform unauthorized actions such as modifying listings or transactions.
V. Vulnerability analysis	Improper Input Validation in Database Queries The application may fail to properly validate or sanitize user inputs before processing SQL queries, increasing the risk of injection attacks due to reliance on dynamic queries instead of parameterized statements. Weak Authentication and Authorization Controls in API The API may lack strong authentication mechanisms and proper access control checks, allowing unauthorized users to access or manipulate resources due to insufficient validation of user identity and permissions.
VI. Attack modeling	Attack tree diagram
VII. Risk analysis and impact	Use Parameterized Queries Implement parameterized queries to prevent SQL injection attacks by ensuring user input is treated strictly as data, reducing the risk of unauthorized database access. Enforce Least Privilege Access Limit database and system permissions to only what is necessary, reducing the impact of a potential compromise and preventing unauthorized data access or modification. Strong Authentication and Authorization Implement secure authentication mechanisms and enforce proper access controls to ensure only authorized users can access system resources and perform sensitive actions. Multi-Factor Authentication (MFA) and Strong Password Policies Require strong passwords and MFA to reduce the likelihood of unauthorized access due to compromised credentials or brute-force attacks.
